

Part 1: Zero-Trust Security Principles (Word Document Draft)

Document Title: Zero-Trust Security Framework – Guiding Principles

Version: 1.0

Audience: IT, Security, Compliance, and Business Stakeholders

1. Verify Explicitly

Always authenticate and authorize based on all available data points, including user identity, location, device health, service or workload, data classification, and anomalies.

2. Use Least Privilege Access

Restrict user and system access with just-in-time (JIT) and just-enough-access (JEA) policies. Limit administrative roles and rely on risk-based adaptive policies.

3. Assume Breach

Operate with the mindset that an attacker is already present in the environment. Segment networks by workload, encrypt all traffic, and continuously monitor for threats.

4. Micro-Segmentation

Enforce granular per-resource policies. Prevent lateral movement by isolating applications, data, and devices into logical segments.

5. Continuous Monitoring & Analytics

Log and inspect all traffic (north-south and east-west). Use real-time analytics and behavioral monitoring to detect anomalies and trigger automated responses.

6. Device & Endpoint Trust

No device is inherently trusted. Require real-time compliance checks (patch level, antivirus, disk encryption) before granting access.

7. Data & Application Protection

Classify and encrypt data at rest, in transit, and in use. Apply dynamic access controls based on data sensitivity and application risk.

8. User Identity & Authentication

Enforce multi-factor authentication (MFA) for all users, services, and privileged accounts. Eliminate static passwords where possible (use passwordless or certificate-based auth).

Control ID	Principle	Action Item	Priority (H/M/L)	Responsible Role	Evidence / Tool	Status (Not Started/In Progress/Complete)	Completion Date
ZT-01	Verify Explicitly	Enforce MFA for all access requests	H	IAM Admin	Azure AD / Okta logs		
ZT-02	Least Privilege	Review and remove stale admin accounts	H	Security Analyst	Access review report		
ZT-03	Assume Breach	Enable network micro-segmentation using NSGs/firewall policies	H	Network Eng.	Segmentation policy doc		
ZT-04	Continuous Monitoring	Deploy SIEM with user and entity behavior analytics (UEBA)	H	SecOps	SIEM alert dashboard		
ZT-05	Device Trust	Enforce device compliance policies (e.g., Intune, CrowdStrike)	M	Endpoint Admin	Compliance report		
ZT-06	Data Protection	Classify sensitive data and apply encryption at rest (AES-256)	H	Data Gov	Data catalog + KMS logs		
ZT-07	Identity Auth	Remove legacy auth protocols (POP3, IMAP, SMTP auth)	M	IAM Admin	Auth protocol report		
ZT-08	Micro-Segmentation	Implement JIT access for privileged roles	M	Sec Engineer	PAM solution logs		